

	LINEAMIENTOS DE GOBIERNO DE APIS			
	NOMBRE	CARGO	FECHA	Código: GTI-OT00X
Elaborado por:	Xiomara Llican	Analista de Procesos y Mejora Continua	02/03/2026	
Revisado por:	Jonathan Torres	Arquitecto de Soluciones		Versión: 0X
Aprobado por:	José Salazar	Jefe de Arquitectura, Base de datos y Data Management.		Página 1 de 20

1. OBJETIVO:

Establecer la nomenclatura estándar y las mejores prácticas para el diseño, creación y administración de APIs en el ecosistema híbrido multicloud de Atlantic City (AWS, GCP, Azure y On-Premise), con el fin de garantizar una gobernanza organizada, segura, trazable y escalable.

2. ALCANCE:

Este lineamiento aplica al área de Desarrollo de Aplicaciones y al equipo de Plataforma TI, así como proveedores externos involucrados en el diseño e implementación de APIs de aplicación obligatoria para la CORPORACIÓN TURÍSTICA PERUANA S.A.C. (CTP), así como para sus empresas vinculadas, relacionadas, filiales y/o subsidiarias, incluyendo —de manera enunciativa más no limitativa— a CORPORACIÓN TURÍSTICA CURAZAO B.V. (CTC), y para todos los colaboradores, áreas y responsables que intervengan en los procesos regulados por el presente documento.

Incluye todos los sistemas publicados bajo los dominios corporativos:

- casinoatlanticcity.com
- acity.com.pe
- acity.pe
- acity.store

3. TERMINOLOGÍA:

3.1. API (Application Programming Interface): Interfaz que permite la comunicación entre sistemas o aplicaciones mediante contratos definidos de request/response.

3.2. FQDN (Fully Qualified Domain Name): Nombre de dominio completo que identifica de forma única un host en la red, incluyendo hostname y dominio.

3.3. Vertical: Identificador del contrato según la audiencia del servicio: col(Casino Online), caf(Casino Físico), adm(Backoffice), acity(transversal).

3.4. Capability: Agrupación funcional de alto nivel dentro de un sistema. Define el perfil de seguridad, SLO/SLA y gobernanza de un conjunto de endpoints.

3.5. Path: Es la parte de una URL que identifica la ubicación de un recurso dentro de un servidor o API, permitiendo que el sistema determine qué operación o servicio debe ejecutarse

3.6. Rate Limiting: Un "límite de velocidad". Evita que un cliente o un atacante haga miles de peticiones por segundo y colapse el sistema de Atlantic City

3.7. Path de cardinalidad controlada: Path cuyos segmentos son valores fijos y conocidos en tiempo de diseño, sin variables dinámicas por request.

3.8. Fachada: Capa de exposición que intermedia entre un origen de datos (ej. Data Lake) y el consumidor final, aplicando el contrato y controles del dominio de audiencia.

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 2 de 20

- 3.9. Origen Data Product:** Dominio acity.store que representa datos originados en el Data Lake / Data Products (GCP). No es una audiencia; es un origen.
- 3.10. Control Plane:** Componente centralizado responsable de configuración, gobernanza, ciclo de vida, políticas y analítica de APIs. No debe ser un punto crítico para el runtime.
- 3.11. Gateway:** Es un punto de acceso centralizado que controla la comunicación entre clientes y servicios backend, gestionando aspectos como autenticación, enrutamiento, seguridad, monitoreo y transformación de solicitudes.
- 3.12. Data Plane / API Gateway:** Componente de ejecución que procesa el tráfico real, aplica políticas y enruta a backends. Debe operar de forma autónoma ante la caída del Control Plane.
- 3.13. Criticality Tier:** Clasificación de criticidad que determina SLOs de latencia, límites de rate limiting y prioridad de soporte.
- 3.14. Versionamiento semántico:** Esquema MAJOR.MINOR.PATCH donde MAJOR implica breaking changes, MINOR agrega compatiblemente y PATCH corrige sin cambio de contrato.
- 3.15. Backend:** Sistema o servicio de destino que implementa la lógica de negocio y procesa la operación real detrás de una API; el gateway solo enruta, protege y controla el tráfico hacia él.
- 3.16. WAF (Web Application Firewall):** es un firewall especializado que protege aplicaciones web (como páginas web, APIs o sistemas en línea) contra ataques provenientes de internet
- 3.17. VPN:** Mecanismo de conectividad privada y segura entre planos, nubes o datacenter, usado para proteger la comunicación entre componentes de la plataforma API Management.
- 3.18. Squad:** Equipo de trabajo responsable del diseño, desarrollo, prueba y operación de un conjunto de APIs o capacidades de negocio dentro de un dominio específico.
- 3.19. HTTP:** Protocolo base de comunicación para exponer e invocar APIs, sobre el cual se aplican métodos, códigos de respuesta, seguridad y observabilidad.
- 3.20. SLOS:** Objetivos de nivel de servicio definidos para una API, usados para gobernar latencia, criticidad, soporte y expectativas operativas por tipo de endpoint.
- 3.21. SLOS P99:** Objetivo de rendimiento que establece el tiempo máximo esperado para el 99% de las solicitudes de una API, especialmente en servicios transaccionales críticos.
- 3.22. SLOS P95:** Objetivo de rendimiento que establece el tiempo máximo esperado para el 95% de las solicitudes, usado para medir desempeño de endpoints críticos y estándar.
- 3.23. Metadata:** Conjunto de atributos obligatorios declarados en el contrato OpenAPI para clasificar, gobernar, buscar y aplicar políticas sobre una API en el portal y en la plataforma de gobierno.
- 3.24. RBAC(Role-Based Access Control):** Modelo de control de acceso basado en roles, que permite definir qué usuarios o sistemas pueden consumir o gestionar APIs según permisos asignados.
- 3.25. ADR(Architecture Decision Record):** Documento que registra decisiones arquitectónicas relevantes, incluyendo contexto, alternativas evaluadas, decisión tomada y sus implicancias.

4. DOCUMENTOS DE REFERENCIA:

No aplica.

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 3 de 20

5. LINEAMIENTOS:

5.1. LINEAMIENTOS GENERALES

- 5.1.1.** Es responsabilidad del Líder difundir y/o comunicar el presente documento a todos los colaboradores involucrados, así como de velar por el cumplimiento del mismo y dictar las disposiciones de detalle para alcanzar la finalidad del presente.
- 5.1.2.** Ante cualquier cambio del documento producto de alguna observación por auditoría, normativa legal y/o mejora de procesos, es responsabilidad del Usuario Líder, solicitar de manera formal mediante correo a los Líderes del área de Procesos y Mejora Continua la actualización del mismo.

5.2. GOBIERNO Y RESPONSABILIDADES

- 5.2.1.** Es responsabilidad del Jefe de Arquitectura, Base de datos y data management difundir y velar por el cumplimiento del presente lineamiento en todos los equipos involucrados.
- 5.2.2.** Ante cambios producto de auditoría, normativa legal o mejora de procesos, el equipo solicitante gestionará formalmente la actualización ante el Área de Arquitectura TI
- 5.2.3.** Toda excepción debe solicitarse formalmente al Jefe de Arquitectura, Base de datos y data management, documentarse con justificación técnica, aprobarse con fecha de expiración y registrarse en inventario.

5.3. PRINCIPIOS DE SEGURIDAD

- 5.3.1.** Los presentes principios constituyen el marco normativo rector que garantiza que la seguridad se integre como un componente fundamental en la arquitectura desde su concepción, mitigando el riesgo de implementaciones reactivas o correctivas de última hora. Estos fundamentos establecen los estándares obligatorios de gobernanza, observabilidad y protección de datos para el ecosistema de la empresa.
- 5.3.2.** Todos los controles técnicos del presente lineamiento se fundamentan en los siguientes principios. Ningún diseño de API en el ecosistema de Atlantic City puede omitir estas bases fundamentales, que se indican en los siguientes puntos:

- **Defense in Depth (Defensa en Profundidad):** Establece una arquitectura de protección multinivel que elimina los puntos únicos de fallo en la seguridad.

Capas de seguridad en cada nivel:

- Perímetro: WAF y balanceadores
- Red: segmentación, microsegmentación, security groups, VPN/peering entre planos. Aplicación: políticas en gateway AuthN, AuthZ, rate limiting, schema validation, masking).
- Datos: cifrado en tránsito TLS 1.2/1.3) y en reposo donde aplique.
- Identidad: autenticación y autorización en cada request.
- **Zero Trust: (Confianza Zero):** Invalida cualquier presunción de confianza, incluso dentro de la red corporativa interna. Exige que toda comunicación entre sistemas, sin

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 4 de 20

excepción, sea continuamente autenticada y autorizada, operando estrictamente bajo el principio de mínimo privilegio

No existe confianza implícita, incluso internamente:

- Toda comunicación debe ser autenticada y autorizada.
- Verificación continua de identidad y contexto.
- Mínimo privilegio (least privilege).
- Microsegmentación de red.
- **Security by Design (Seguridad por diseño):** Impone que los controles de seguridad se declaren e integren en la especificación de la API desde la fase de diseño arquitectónico

Seguridad integrada en la especificación:

- Validación de JWT en el Data Plane (con caché de JWKS, no delegada al backend como único control.
- Políticas obligatorias desde el diseño.
- Cifrado end-to-end por defecto.
- Auditoría de accesos declarada y exigible.
- **Principio rector del Gateway (Especialmente un APIT Gateway):** Dictamina que el componente de ejecución (API Gateway) debe mantenerse estructuralmente ligero y altamente performant

El Gateway debe ser ligero y performante. Las transformaciones complejas y la lógica de negocio se ejecutan en el backend

Política	Permitida en Gateway	Impacto en performance
Validación JWT (con caché JWKS)	Sí	Bajo
Rate limiting / quotas (in-memory)	Sí	Muy bajo
Header injection / masking de PII	Sí	Bajo
Logging y trazabilidad (traceld)	Sí	Bajo
Transformaciones complejas de payload	No (backend)	Alto

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 5 de 20

Orquestación multi backend	No (backend)	Alto
Lógica de negocio condicional	No (backend)	Alto

5.4. DOMINIOS OFICIALES POR AUDIENCIA Y ORIGEN

5.4.1. El dominio oficial de una API se determina estrictamente por el público que la consumirá (la audiencia) o por la fuente maestra de la información (el origen). Queda prohibido definir esta dirección web basándose en la infraestructura tecnológica o la nube que aloja el sistema por detrás (backend).

Contexto	Dominio	Descripción
COL – Invitado online	casinoatlanticcity.com	APIs consumidas por el canal de Casino Online y el principal beneficiado es el invitado de casino online
CAF – Invitado físico	acity.com.pe	APIs consumidas por el canal de Casino Físico y el principal beneficiado es el invitado de casino físico
ADM Backoffice	acity.pe	APIs para colaboradores internos
Origen Data Product	acity.store	APIs originadas en Data Lake / Data Products

- Regla maestra: el dominio se elige por audiencia/origen, nunca por la nube.

Ejemplos de FQDN reales:

1. <https://api-col.casinoatlanticcity.com>
2. <https://api-caf.acity.com.pe>
3. <https://api-corp.acity.pe>

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 6 de 20

4. <https://api-data.acity.store>

5.5. REGLA OBLIGATORIA: DATA LAKE HACIA EL INVITADO DEBE USAR FACHADA

5.5.1. Si un dato originado en api-data.acity.store llega al invitado, debe exponerse por el dominio COL o CAF. Está prohibido exponer [acity.store](https://api-data.acity.store) directamente al invitado.

Ejemplo — mismo caso funcional, dos endpoints distintos:

1. El invitado consume (a través de la fachada):

POST <https://api-col.casinoatlanticcity.com/col/v1/partner/ivr/consultas/invitados/obtener>

2. La fachada consume internamente (origen Data Product):

POST <https://api-data.acity.store/col/v1/internal/ivr/consultas/invitados/obtener>

5.6. NOMENCLATURA ESTÁNDAR DE URL

5.6.1. Fórmula única:

<https://api-{sistema}.{dominio}/{vertical}/{version}/{capability}/{modulo}/{submodulo}/{recursoPrincipal}/{subrecurso}/{operacion}>

Nota de notación: `[/{subrecurso}]` indica segmento opcional. El resto de segmentos son obligatorios.

5.6.2. Reglas transversales

- Minúsculas y kebab-case en todos los segmentos.
- Prohibido incluir PII o secretos en URL (path, query string o fragment).
- Prohibido usar valores dinámicos o variables en el path.
- `{modulo}` y `{submodulo}` son siempre obligatorios. Si no aplica, usar defaults: `{modulo}=core` y `{submodulo}=default`.

5.7. DEFINICIÓN DE SEGMENTO

5.7.1. `{sistema}`: Identificador estable del sistema/producto (kebab-case). Prohibido usar nombres temporales de proyectos, squads o ambientes.

Ejemplos:

API-{Sistema}

API-COL (COL: Sistema de casino online)

API-CAF (CAF: Sistema de Casino Físico)

API-CORP (CORP: Sistema Corporativo Atlantic 360)

5.7.2. `{vertical}` — catálogo cerrado

Valor	Audiencia
col	Invitado online
caf	Invitado físico
adm	Backoffice

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 7 de 20

acity	Transversal
-------	-------------

Ejemplos reales:

1. POST <https://api-col.casinoatlanticcity.com/col/v1/auth/sesion/acceso/autenticacion/iniciar-sesion>
2. POST <https://api-caf.acity.com.pe/caf/v1/integracion/ebsgw/consultas/invitados/obtener>
3. POST <https://api-corp.acity.pe/adm/v1/mantenimientos/catalogos/financieros/monedas/listar>

5.7.3.{versión}

Versión mayor del contrato: v1 , v2 , v3 ...

- MAJOR sube cuando hay incompatibilidad de contrato (breaking changes). Obliga a crear un nuevo path /v{N} .
- MINOR agrega funcionalidad compatible. No cambia el path; sí actualiza OpenAPI.
- PATCH corrige errores sin cambio de contrato.

La subida de MAJOR requiere aprobación del Arquitectura TI y plan de depreciación.

5.7.4.{capability}: Define las características que tiene un sistema cuando se necesite agregar un nuevo capability se debe llevar a revisión y aprobación del Área de Arquitectura TI de acuerdo a este catálogo base:

#	Capability	Descripción
1	auth	Sesión, tokens, OTP
2	mantenimientos	Capacidad destinada a las operaciones del sistema, que implementan la lógica central del negocio y generan valor directo para el proceso funcional o para la experiencia del invitado.
3	reportes	Consultas pesadas, exportaciones, jobs
4	files	Upload/download, URLs firmadas, metadata
5	public	Se utiliza exclusivamente para APIs expuestas directamente a internet sin restricciones de acceso por red privada, destinadas a consumo abierto o semiabierto.
6	integración	Adaptadores, orquestación, webhooks
7	notificación	Envío/gestión de notificaciones y auditoría
8	internal	APIs de consumo interno entre sistemas corporativos o

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 8 de 20

	fachadas hacia backends internos.
--	-----------------------------------

Capabilities adicionales debe solicitar la aprobación correspondiente al área de Arquitectura TI.

Ejemplos normativos por capability:

AUTH (Authentication): Capacidad encargada de gestionar la autenticación y autorización de usuarios o sistemas que acceden a servicios o APIs.

1. POST <https://api-col.casinoatlanticcity.com/col/v1/auth/sesion/acceso/autenticacion/iniciar-sesion>
2. POST <https://api-col.casinoatlanticcity.com/col/v1/auth/sesion/acceso/autorizacion/generar-token>
3. POST <https://api-col.casinoatlanticcity.com/col/v1/auth/sesion/acceso/autorizacion/validar-token>
4. POST <https://api-col.casinoatlanticcity.com/col/v1/auth/sesion/acceso/autorizacion/revocar-token>

MANTENIMIENTOS: Capacidad que permite la administración y gestión de información base de un sistema.

1. POST <https://api-corp.acity.pe/adm/v1/mantenimientos/seguridad/usuarios/tipos-usuario/listar>
2. POST <https://api-corp.acity.pe/adm/v1/mantenimientos/seguridad/usuarios/tipos-usuario/guardar>
3. POST <https://api-corp.acity.pe/adm/v1/mantenimientos/seguridad/usuarios/tipos-usuario/actualizar>
4. POST <https://api-corp.acity.pe/adm/v1/mantenimientos/seguridad/usuarios/tipos-usuario/eliminar>

REPORTES: Capacidad destinada a la generación, consulta y distribución de información analítica o reportes operativos.

1. POST <https://api-corp.acity.pe/adm/v1/reportes/marketing/campanias/promociones/generar-reporte>

FILES: Capacidad que permite la carga, almacenamiento, consulta y descarga de archivos dentro de la plataforma.

1. POST <https://api-corp.acity.pe/adm/v1/files/contratos/default/archivos/guardar>
2. POST <https://api-corp.acity.pe/adm/v1/files/contratos/default/achivos/obtener>

PUBLIC: Capacidad que permite publicar y exponer servicios o APIs para consumo de aplicaciones externas o de terceros, garantizando seguridad, control de acceso y gestión centralizada.

1. POST <https://api-corp.acity.pe/caf/v1/public/marketing/premios/jackpots/listar>

INTERNAL: Capacidad que permite publicar y exponer servicios o APIs para consumo interno garantizando seguridad, control de acceso y gestión centralizada.

1. POST <https://api-data.acity.store/col/v1/internal/ivr/default/invitados/obtener>

INTEGRACIÓN: Capacidad que permite la interoperabilidad entre sistemas internos y externos mediante servicios, APIs o mecanismos de mensajería, facilitando el intercambio de información entre plataformas.

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 9 de 20

1. **POST** <https://api-corp.casinoatlanticcity.com/col/v1/integracion/sunat/finanzas/tipo-cambio/obtener>
2. **POST**
<https://api-corp.casinoatlanticcity.com/col/v1/integracion/reniec/identidad/personas/obtener-por-documento>

NOTIFICACIÓN: Capacidad que permite el envío y gestión de notificaciones hacia usuarios o sistemas mediante distintos canales de comunicación.

1. **POST** <https://api-corp.acity.pe/adm/v1/notificacion/canales/sms/enviar>
2. **POST** <https://api-corp.acity.pe/adm/v1/notificacion/canales/email/enviar>
3. **POST** <https://api-corp.acity.pe/adm/v1/notificacion/canales/email/programar>

RESTRICCIÓN OBLIGATORIA: Los capabilities anteriores son normativos. Las implementaciones existentes que difieran de este estándar deben incluirse en el plan de remediación aprobado por el Área de Arquitectura TI.

5.7.5.{módulo} y {submódulo}

- Default {módulo} : core solo se usa cuando no exista un módulo funcional aplicable
- Default {submódulo} : default solo se usa cuando no exista un submódulo funcional aplicable
- Ambos en kebab-case. Pueden ser compuesto

Ejemplos

1. **POST** <https://api-col.casinoatlanticcity.com/col/v1/auth/sesion/acceso/autenticacion/iniciar-sesion>
2. **POST** <https://api-corp.acity.pe/adm/v1/integracion/reniec/identidad/personas/obtener-por-documento>
3. **POST** <https://api-data.acity.store/col/v1/internal/ivr/default/invitados/obtener>

RESTRICCIÓN OBLIGATORIA

El uso de core y default debe ser justificado en el diseño de la API y validado por el área de arquitectura TI.

5.7.6.{recurso Principal} y [{subrecurso}]

- Recurso principal: sustantivo (preferiblemente plural) en kebab-case.
- Subrecurso: opcional, máximo 1 nivel, fijo (sin variables).
- Prohibido: verbos, camelCase, underscore, PII.

POST <https://api-corp.acity.pe/adm/v1/reportes/marketing/default/promociones/generar-reporte>

5.7.7.{operación} : Segmento que representa la acción a ejecutar sobre el recurso.

Los nombres de operación deben registrarse y validarse previamente en un catálogo corporativo, con el objetivo de mantener consistencia semántica, evitar duplicidades y asegurar un estándar en la nomenclatura.

La gestión y gobierno de este catálogo es responsabilidad del Área de Arquitectura TI.

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 10 de 20

5.8. PROHIBICIÓN DE VARIABLES EN EL PATH

5.8.1. Está terminantemente prohibido el uso de segmentos variables o dinámicos en el path, incluyendo: `{id}` , `{uuid}` , `{dni}` , `{email}` , `{token}` , `{código}` , `{proxy+}`.

- Regla de transporte de identificadores y criterios:
 - No se admiten en el path guiones bajos “_”
 - Todos los identificadores y criterios de consulta se transportan en el body del request
 - Está prohibido transportarlos por query string.

Ejemplo correcto — obtener por ID:

1. POST https://api

ebsgw.acity.com.pe/caf/v1/public/core/default/invitados/obtener

Body: { "id": "12345" }

Ejemplo correcto — obtener múltiples IDs (bulk):

2.POST https://api

ebsgw.acity.com.pe/caf/v1/public/core/default/invitados/obtener

Body: { "ids": ["12345", "67890", "11121"] }

5.9. MÉTODOS HTTP

5.9.1. POST — método estándar para negocio (obligatorio por defecto)

Todo endpoint de negocio opera con POST: listar, obtener, buscar, guardar, actualizar, eliminar, integraciones, notificación, reportes y files.

- El body es obligatorio y debe ser validado por esquema OpenAPI/JSON Schema).
- Idempotencia obligatoria en operaciones críticas mediante requestId o Idempotency-Key .

5.9.2. GET — uso restringido

Permitido únicamente para health/metadata no sensible y bajo aprobación de Arquitectura TI.

- Sin body.
- Sin PII en URL.

Ejemplo: **GET https://api-corp.acity.pe/adm/v1/public/core/default/health/obtener**

5.9.3. HEAD — principalmente files

Para metadatos ETag, tamaño, last-modified) sin descargar contenido.

- El identificador se transporta por header (X-File-Id), nunca en el path.

Ejemplo: **HEAD https://api-corp.acity.pe/adm/v1/files/documentos/contratos/archivos/obtener**

Header:

1. X-File-Id: abc-123

5.9.4. OPTIONS — solo para public con CORS

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 11 de 20

Únicamente cuando **public** sea consumida desde navegador y se requiera CORS.
Allowlist estricta de orígenes, métodos y headers.

Ejemplo: **OPTIONS** <https://api>

col.casinoatlanticcity.com/col/v1/public/marketing/default/promociones/buscar

5.9.5.PUT / PATCH / DELETE — condicional

Se habilitan solo si existe beneficio claro, compatibilidad probada con clientes/WAF/gateway, documentación en OpenAPI y aprobación formal de Arquitectura TI mediante ADR. Si no hay justificación aprobada, se mantiene POST.

5.9.6.Regla de habilitación de métodos distintos de POST

Un método distinto de POST se habilita solo si:

- Existe beneficio claro (semántica, eficiencia o compatibilidad técnica).
- No rompe gobernanza/analítica (paths fijos, sin variables).
- Hay compatibilidad probada con clientes, WAF/gateway y observabilidad.
- Está documentado en OpenAPI.
- Se aprueba por Arquitectura TI mediante ADR.

5.10. CONTRATOS ESTÁNDAR DE REQUEST/RESPONSE

5.10.1. Body de listar

```
{
  "paging": { "page": 1, "size": 50 },
  "sort": { "field": "nombre", "order": "asc" },
  "filters": {}
}
```

6

Reglas:

- size máximo: 200.
- Defaults si se omite paging : { "page": 1, "size": 50 } .

5.10.2. Body de buscar

```
{
  "filters": { "estado": "activo", "fechaDesde": "2026-01-01" },
  "paging": { "page": 1, "size": 50 },
  "sort": { "field": "fecha", "order": "desc" },
  "fields": ["id", "nombre", "estado"]
}
```

5.10.3. Body de obtener — registro único

```
{ "id": "abc-123", "fields": ["id", "nombre", "estado"] }
```

5.10.4. Body de obtener — bulk

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 12 de 20

{ "ids": ["abc-123", "abc-456", "abc-789"], "fields": ["id", "nombre"] }

5.10.5. Envelope de respuesta estándar

Éxito:

```
{
  "data": {},
  "meta": {
    "traceld": "550e8400-e29b-41d4-a716-446655440000",
    "page": 1,
    "size": 50,
    "totalItems": 120,
    "totalPages": 3
  },
  "errors": []
}
```

Error:

5.10.6. Códigos HTTP por operación

Operación	Éxito	Error de cliente	Error de servidor
guardar	201	400 / 422	500
listar , obtener , buscar	200	400 / 404	500
actualizar , cambiar estado	200	400 / 404 / 422	500
eliminar	200	404	500
auth (iniciar sesión, generar token)	200	401 / 403	500
exportar, generar - reporte	202 (async) / 200 (sync)	400	500

5.11. CLASIFICACIÓN DE CRITICIDAD DE ENDPOINT

Toda API debe declarar su criticality_tier en la metadata del contrato OpenAPI. Este atributo define SLOs aplicables, rate limiting y prioridad de soporte.

Tier	Tipo	SLO P99	SLO P95	Prioridad soporte
T1 - Crítica	Transaccionales core (auth, apuestas, pagos, caja)	< 250 ms P99.9 400ms)	≤ 1,000 ms	P1 24x7
T2 - Importante	Integraciones, notificaciones, reportes críticos	—	≤ 1,000 ms	P2
T3 - Estándar	Mantenimientos, catálogos, files	—	≤ 2,000 ms	P3
T4 - Experimental	Sandbox, POCs, Draft	Sin SLO	Sin SLO	Mejor esfuerzo

Nota: los SLOs se consolidan y gobiernan en el catálogo corporativo de SLOs; la asignación por endpoint es obligatoria.

5.12. METADATA OBLIGATORIA POR API

Toda API publicada debe declarar los siguientes atributos en info.x-metadata OpenAPI). Esta metadata es usada por el Developer Portal y el sistema de gobernanza para agrupación, búsqueda, aplicación de políticas y cost management. El inventario de APIs es administrado por Arquitectura TI y accesible a través del Developer Portal corporativo.

Atributo	Valores permitidos	Obligatorio
----------	--------------------	-------------

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 14 de 20

business_domain	col , caf , adm , acity	Sí
criticality_tier	T1 , T2 , T3 , T4	Sí
environment	prod , qa , dev	Sí
data_classification	public , internal , confidential, restricted	Sí
owner_team	Nombre del equipo responsable	Sí
lifecycle_status	Ver sección ciclo de vida de APIS	Sí

Ejemplo:

1 info:
2 title: Tipos de Usuario API
3 version: 1.0.0
4 x-metadata:
5 business_domain: adm
6 criticality_tier: T3
7 environment: prod
8 data_classification: internal
9 owner_team: arquitectura-empresarial
10 lifecycle_status: published

5.13. CICLO DE VIDA DE APIs

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 15 de 20

Toda API debe transitar por los siguientes estados. Los cambios deben asociarse a roles, aprobaciones y auditoría.

Estado	Descripción	Visible en Developer Portal	Acepta suscripciones nuevas
Draft	En diseño y desarrollo.	No	No
Staged	Disponible en DEV/QA para pruebas internas.	No	No
Published	Activo en producción.	Sí	Sí
Deprecated	Marcado para retiro. Sigue operativo.	Sí (con aviso)	No
Retired	Fuera de servicio.	No	No
Archived	Historial para consulta y auditoría. Retención mínima: 7 años.	Solo consulta	No

Transiciones permitidas:

- 1 **Draft → Staged → Published → Deprecated → Retired → Archived**
- 2 **Published → Deprecated (requiere plan y aprobación de Arquitectura TI)**
- 3 **Deprecated → Published (reversión, requiere aprobación de Arquitectura TI)**

Reglas de deprecación:

- Período mínimo de deprecación antes del retiro: 90 días calendario.
- Notificar a consumidores con fecha estimada de retiro.
- Mantener operativo el path durante el período de deprecación.
- La versión reemplazo debe estar Published antes de marcar Deprecated.

5.14. CONTROLES OBLIGATORIOS DE API MANAGEMENT

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 16 de 20

Aplican a todas las APIs publicadas. Son condición necesaria para habilitar métodos distintos de POST y para promover una API a Published.

5.14.1. Autenticación AuthN

Dominio	Mecanismo	Referencia
COL	OIDC/OAuth2 JWT + controles de canal	Amazon Cognito
CAF	OIDC/OAuth2	Keycloak (IDP local)
ADM	SSO corporativo	Entra ID / Keycloak
acitydata	Identidad de servicio JWT y/o mTLS	Nunca token directo de invitado

5.14.2. Métodos soportados por prioridad:

- OAuth 2.0 / OIDC
- Validación JWT (caché JWKS)
- mTLS X.509
- API Key (solo casos controlados; siempre con rate limit y rotación)
- Basic Auth (solo legacy en migración)

Cualquier mecanismo distinto a los anteriores para el dominio CAF debe ser aprobado por el Arquitectura TI y documentado como excepción con justificación técnica y fecha de remediación.

5.14.3. Autorización AuthZ

Autorización por scopes/roles/claims por endpoint (operación) y por producto. Control granular por clientId/partner/plan de suscripción.

- public e integracion con perfil más estricto.
- acitydata con control por dataset/consulta y masking de campos.

5.14.4. Rate Limiting y Quotas

- Rate limit por consumidor (clientId/sub/partner), no solo por IP.
- Valores se definen por capability y criticality tier.
- Respuesta 429 consistente con envelope de error.

5.14.5. Logging seguro y auditoría

- Traceld obligatorio en todos los requests (entrada y salida).
- Prohibido registrar: Authorization , tokens, passwords, OTP, PII sin masking. Masking obligatorio de PII DNI, email, teléfono, datos financieros).

- Auditoría obligatoria para: guardar , actualizar , eliminar , cambiar estado .

5.14.6. Cache-Control

- Default en datos sensibles/personalizados: Cache-Control: no-store
- Caching solo con aprobación explícita de Arquitectura TI y registrado en el inventario de APIs del Developer Portal corporativo.

5.14.7. Schema Validation

- Validación obligatoria del body contra OpenAPI/JSON Schema.
- Rechazar campos no declarados (additionalProperties: false).
- Definir límites de tamaño de payload por capability.

5.14.8. Idempotencia

- Obligatoria en operaciones críticas: integraciones, webhooks, guardar , actualizar
- Implementar con Idempotency-Key o requestId .
- En requests duplicados dentro de ventana de idempotencia, retornar respuesta determinística.

5.14.9. Conectividad Control Plane ↔ Data Planes

- TLS 1.2/1.3 obligatorio.
- mTLS o mecanismo equivalente.
- Preferencia por redes privadas VPN/peering/PrivateLink) para gestión.
- Los Data Planes deben operar autónomamente ante caída del Control Plane con la última configuración válida.

5.15. MODELO DE ROLES Y ACCESOS (RBAC)

5.15.1. Roles por equipo y entorno

Equipo	PROD	QA	DEV
Operaciones	Administración completa	Solo lectura	Solo lectura
Arquitectura	Gobierno y visibilidad total	Gobierno	Gobierno
Desarrollo	Sin acceso directo	Administración completa	Administración completa
Seguridad	Auditoría y revisión de políticas	Auditoría	Auditoría

5.15.2. Roles en la plataforma de API Management

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 18 de 20

Rol	Asignado a	Permisos
Platform Administrator	Operaciones	Control total global
API Manager	Arquitectura + Desarrollo QA/DEV	Crear/editar APIs, productos, políticas
Developer Portal Manager	Arquitectura	Contenido del portal, aprobaciones
Analytics Viewer	Arquitectura + Operaciones	Lectura de métricas
Catalog Manager — PROD	Operaciones	Administrar catálogo PROD
Catalog Manager — QA Desarrollo	Desarrollo	Administrar catálogo QA
Catalog Manager — DEV	Desarrollo	Administrar catálogo DEV

5.15.3. Roles en Developer Portal (consumidores)

Rol	Permisos
Administrator	Gestionar organización, aprobar suscripciones
Developer	Crear apps, suscribirse, try-it-out en entornos permitidos
Viewer	Visualizar catálogo y documentación

5.16. GESTIÓN POR ENTORNOS DEV / QA / PROD

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 19 de 20

- Separación estricta de configuraciones y credenciales entre entornos.
- Promoción DEV QA PROD exclusivamente por CI/CD. Prohibida promoción manual. try it out del Portal solo a Sandbox/QA. Nunca a PROD.
- APIs Draft/Staged solo en DEV/QA.
- Toda API en PROD debe haber completado pruebas funcionales, seguridad y carga en QA.
- Los Data Planes de DEV/QA pueden ser dedicados o compartidos; la decisión debe estar documentada con justificación de riesgos y beneficios, y aprobada por Arquitectura TI.

5.17. APLICABILIDAD POR PROTOCOLO

5.17.1. REST / RPC HTTP: aplica totalmente.

5.17.2. Webhooks: POST obligatorio. Path fijo. Se permite `/{{proveedor}}/{{evento}}` solo si ambos pertenecen a catálogo cerrado.

POST `https://api-corp.acity.pe/adm/v1/integracion/webhooks/alternar/apuestas/recibir-webhook`

5.17.3. SOAP: aplica parcialmente. Path fijo y POST. La operación vive en SOAPAction/body. `{serviceName}` debe ser de catálogo.

POST `https://api-corp.acity.pe/adm/v1/integracion/legados/sap/soap/contrato-service`

5.17.4. GraphQL: endpoint fijo por contexto. POST estándar. Gobernanza por operationName de catálogo cerrado y/o persisted queries. Playground deshabilitado en PROD.

POST `https://api-corp.acity.pe/col/v1/public/auth/sesion/default/graphql`

5.17.5. gRPC: aplica parcialmente HTTP/2. La operación se define en el proto, no en el path HTTP. Usar para comunicación entre microservicios internos de alto rendimiento. El path HTTP sigue la fórmula estándar hasta el nivel de recurso:

POST `https://api-corp.acity.pe/adm/v1/integracion/legados/sap/grpc/contrato-service`

5.17.6. WebSockets: aplica parcialmente. El path de conexión es fijo y sigue la fórmula estándar. La gobernanza se aplica en el handshake inicial AuthN/AuthZ) y en los mensajes según el contrato declarado.

WSS `https://api-col.casinoatlanticcity.com/col/v1/public/jackpots/default/jackpots/suscribir`

5.18. CHECKLIST DE CUMPLIMIENTO PARA PUBLICACIÓN

Condición necesaria para promoción a QA/PROD:

- a) URL cumple fórmula (dominio + vertical + versión + capability + módulo + submódulo + recurso + operación).
- b) Sin variables en path.
- c) Sin PII en URL.
- d) Sin query string para identificadores.
- e) OpenAPI completo, versionado y validado.

	LINEAMIENTOS DE GOBIERNO DE APIS	Código: GTI-OT00X
		Versión: 01
		Página 20 de 20

- f) AuthN/AuthZ implementado y probado.
- g) Rate limiting/quota configurado por consumidor.
- h) Logging seguro con traceld y masking de PII.
- i) Cache-Control correcto.
- j) Schema validation activo.
- k) Idempotencia aplicada donde corresponde.
- l) Pruebas mínimas: funcionales, contrato, seguridad, performance (si aplica).
- m) Documentación en Portal con hardening (sin exponer secretos; try it out solo en entornos permitidos).

5.19. EXCEPCIONES Y ADR

5.19.1. Cuándo aplica excepción

Solo si existe razón técnica/regulatoria que impide cumplir el lineamiento, se demuestra impacto, alternativas y mitigaciones, y se aprueba por Arquitectura TI.

5.19.2. Contenido mínimo del ADR

- Contexto.
- Decisión.
- Alternativas evaluadas.
- Implicancias (seguridad, observabilidad, operación, costo).
- Plan de mitigación.
- Fecha de expiración (si es transicional).

6. FORMATOS:

No aplica.

7. ANEXOS:

No aplica.

8. CONTROL DE CAMBIOS:

No aplica.